TRUST CENTER

Trust Center

How Truehound protects your data, what it has in place today, and what it does not have yet. Every statement is true of the product as it ships.

LAST UPDATED 2026-10-25

IN PLACE	NOT YET	SOC 2 REPORT	CERTIFICATIONS
21	5	Not yet	None held

CONTACT

truehoundhq@truehound.io

01 Overview

This page lists every security and privacy control Truehound has, and every one it does not have yet. “Not yet” means exactly that: we do not have it, and the plan says what we will do. Nothing here is a claim we cannot show you.

IN PLACE	PARTLY	NOT YET	SUB-PROCESSORS
21	6	5	11

02 Compliance and reports

Not yet Certifications and attestations

Truehound holds no security certification or attestation. No SOC 2 (Type I or Type II), no ISO 27001, no ISO 27701, no HIPAA attestation, no PCI DSS assessment of our own, and no independent penetration test. Our hosting providers publish their own reports for their facilities; those are theirs, not ours. We will not describe Truehound as certified, compliant or audited until an independent party has issued the report.

Plan: SOC 2 Type I readiness is the first step, started when a customer needs it. Until then, the questionnaire answers and the evidence on this page are what we can show.

Not yet SOC 2 report

Truehound does not have a SOC 2 report. We do not claim one, and will not until an independent auditor issues it.

Plan: Start a SOC 2 Type I readiness project when a customer needs it, using the controls on this page as the starting point.

Not yet ISO 27001

Not held, and not planned before SOC 2.

Not yet Independent penetration test

No third party has tested Truehound yet. Our own checks run on every change (see Application security).

Plan: Commission an independent test before accounts hold customer data in production, and share the summary under NDA.

In place Data Processing Agreement

GDPR Article 28 terms, US service-provider terms, Standard Contractual Clauses, a security annex and a sub-processor annex, published and ready to sign.

In place Security questionnaires

A CAIQ-lite style answer pack is published, every answer drawn from how the product works today, with the file that enforces it. We also answer your own questionnaire directly, usually within 5 business days. Email truehoundhq@truehound.io.

03 Data security

In place Data stays in your browser by default

Without an account, tokens, the audit and the workspace are stored in your browser, not on our servers. With an account, your team's workspace is kept in Cloudflare D1.

In place Encryption in transit

HTTPS everywhere; plain HTTP redirects to HTTPS. The site accepts only TLS 1.2 and 1.3, with forward secrecy (measured with SSL Labs, see Security grades).

In place Encryption at rest

App credentials an admin saves, including one-click app sign-ins, are encrypted with AES-256-GCM under a key derived for each workspace (HKDF-SHA256) from a master secret held only in the connector's secret store; connected-app credentials are bound to their workspace and app, and the master key can be rotated. Sessions, invites, API keys and extension keys are stored only as SHA-256 hashes (sign-in link hashes too, once email sign-in is on). Cloudflare encrypts D1 and Workers KV data at rest.

In place What we read, and what we never read

From connected apps: people, accounts, roles, status, dates and grants. Never message, document or email body contents; mailbox discovery is limited to sender, subject and date. Secret values found in code are masked and never kept.

Partly Backups

Cloudflare D1 keeps point-in-time restore for account data automatically (30 days on a paid Workers plan, 7 days otherwise). Demo-form leads in Workers KV have no backup. We have not yet practised a restore.

Plan: Run and record a restore drill before accounts hold customer data in production.

In place Data retention

Retention jobs run every 15 minutes in the connector. Scan history and connected-app scans are kept 90 days (the latest successful scan is always kept); sign-in link records 24 hours; sessions 30 days from your last visit; invites 7 days; review links

for outside reviewers 120 days; extension sign-ins 395 days; demo-form leads 24 months. The Proof log is kept for the life of the workspace, because it is the evidence. The full table is in the Privacy Policy.

In place Erasure

An owner or admin can export everything a workspace holds as one JSON file; an owner deletes the workspace, and everything stored for it, in one step; a person can delete their account. Retention jobs run every 15 minutes (sign-in records 24 hours, scan histories 90 days, extension sign-ins 13 months, leads 24 months). Restore copies expire within 30 days.

04 Application security

In place Credential management

Our own secrets (payment, email, GitHub App, encryption) live in Cloudflare's write-only Worker secrets and GitHub Actions secrets, are pushed by the deploy workflow without being printed, and never reach the browser. Tokens you paste are relayed per request and never stored or logged by our connector.

In place Secure development

TypeScript in strict mode, linting, unit and contract tests, and end-to-end suites. A pre-push gate runs the full validation before code reaches the main branch, the connector deploys only after its own tests run in CI, installs use lockfiles, and GitHub Actions are pinned to exact commits.

In place Browser hardening

A strict Content Security Policy (scripts only from our own site; connections only to our site, our connector and the apps you connect), a referrer policy, fonts served from our own site and no third-party scripts.

In place Open hook script

The script that governs AI agents' tool calls runs on your developers' laptops, so you can read every line before you install it: it is published as a plain file at /hooks/truehound-hook.mjs (needs Node 18 or newer). It redacts secrets on the laptop before anything is sent, sends one small request, gives up after 250 milliseconds, and reads its token from a config file with mode 600.

Partly Vulnerability and patch management

Dependencies are pinned by lockfile and reviewed by hand when upgraded. Automated dependency alerts are not switched on yet.

Plan: Switch on GitHub's dependency alerts and add a dependency audit to CI.

In place Responsible disclosure

A published disclosure policy with safe harbour, a security.txt file, acknowledgement within 1 business day, and fix targets of 14 days for critical and 30 days for high issues.

05 Access control

In place Customer data access

Every account query is limited to the workspace it belongs to; a non-member gets “not found”, and automated tests check it. Owner, admin and member roles limit who can change what, and an approval policy can require a second admin.

In place How Truehound gets access to your apps

You connect with the narrowest read-only sign-in the app offers (for GitHub, a fine-grained read-only token that you create and can revoke; every call is a read). Nothing is changed in an app until a person approves a fix under your approval policy, where the person who proposed a fix can never approve it, and Truehound then reads the app again to verify. AI is optional and runs on your own Anthropic key (bring your own key): Truehound holds no AI key, pays nothing for your AI, and without your key every feature runs on rules and says so. Saved credentials are encrypted per workspace and are never returned to the browser.

Partly Production access

One person, the founder, can reach production (the Cloudflare, GitHub and Stripe accounts). Nobody else has access.

Plan: Confirm and record two-factor sign-in on every production account, and review access each quarter.

Partly Logging

Every change, approval and consent in a workspace is written to the Proof log, a SHA-256 hash chain where tampering shows. The connector keeps no request logs and logs errors without personal data.

Plan: Add retained security logging and alerting for the production accounts.

In place Password security

Truehound has no passwords to steal: you sign in by payment, an activation code, an invite link or a passkey, and connect apps with their own sign-in. Email sign-in links are built but not switched on yet (no email provider is connected), so no sign-in email is sent today. The session cookie is HttpOnly, Secure and limited to our API.

06 Infrastructure

In place Hosting

The website is static files on GitHub Pages, with no server code. The connector and account backend are a Cloudflare Worker, with Cloudflare D1 and Workers KV for storage. We run no servers of our own.

In place Data centers

Physical security is GitHub's and Cloudflare's. Each publishes its own SOC 2 and ISO 27001 reports for its facilities.

In place Separate production

Production deploys only from the main branch, by CI. Development runs locally on in-memory stores and fixtures, and the public demo uses fictional data only. Customer data is never copied out of production.

In place Status page

A public status page shows the connector and site health, with samples kept 100 days. It has no incident feed yet, so incident notices go to affected customers by email. It is not an uptime commitment.

Partly Business continuity and disaster recovery

The site and connector can be rebuilt and redeployed from source, which is kept in two private repositories. There is no uptime commitment unless an order form gives one.

Plan: Write and test a recovery runbook with target times, alongside the restore drill.

07 Corporate security

In place Devices

Truehound is one person. The founder's work computer uses full-disk encryption (FileVault, checked 2026-10-22).

Not yet Security training

There are no employees to train yet.

Plan: Security onboarding for every hire before they get any access, and training each year.

Partly Incident response

The process, in order. Report: anyone can report to truehoundhq@truehound.io, and we acknowledge within 1 business day. Triage: we assess severity within 5 business days. Contain and fix: critical issues get a first fix or mitigation within 14 days and high within 30, per the disclosure policy. Notify: we tell affected customers of a personal data breach by email to their account owners within 72 hours of confirming it. Check the service: the status page shows connector and site health. Learn: the disclosure policy and this page are updated when something changes. Not yet done: a rehearsal of this process.

Plan: Write the incident runbook and rehearse it once before accounts go live.

08 Security grades

Measured by hand on the date shown, against truehound.io. We publish the grade we got, not the one we want.

CHECK	GRADE	MEASURED	WHY	FIX
SSL Labs (Qualys)	B	2026-10-22	TLS 1.2 and 1.3 only, with forward secrecy, but GitHub Pages still offers two older TLS 1.2 cipher suites (RSA key exchange, CBC) and sends no HSTS header. We cannot change GitHub Pages' TLS settings.	Put Cloudflare in front of the site (a DNS change) with modern ciphers only and HSTS, which should reach A or A+.
Security Headers (securityheaders.com)	F, by its rules	2026-10-22	The service blocks automated checks, so we read the response headers ourselves: GitHub Pages sends none of the six it grades (Content-Security-Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy). Our Content Security Policy and referrer policy are set inside the page, which browsers enforce but the grader does not count.	The same Cloudflare switch lets us send all six as real headers.
SecurityScorecard	Not measured	2026-10-22	It needs an account we do not have.	Measure once the Cloudflare switch is done.

09 Data flow

Where your data goes, in the order it moves. How much of this applies depends on whether you use the free scan and browser mode, or an account with the access agent.

Data flow: step, what moves, where it goes, and whether it is kept

STEP	WHAT MOVES	WHERE	KEPT?
You run a scan in browser mode	A token you paste, and what GitHub or your identity provider returns	From your browser straight to that provider. Some GitHub code searches pass through our connector on Cloudflare for that one request.	The token is used for the request and is not stored by us. The audit stays in your browser.
You create an account	Your email, workspace name and role	Our database on Cloudflare (D1). Resend, for account email, is not engaged yet because email is not switched on.	Yes, until you delete the workspace or ask us to.
An admin saves a connection for the agent	The app credential, so the agent can watch and act when nobody is present	Our database, encrypted per workspace.	Yes, only when an admin chooses to save it. Removing the connection deletes it.
The agent reads and reports	People, accounts, roles and sign-in facts from the apps you connected	Our database, to build the inventory, reviews and the audit trail.	Yes, on the retention schedule in the Privacy Policy.
You pay	Billing contact and plan; card details go straight from you to Stripe	Stripe.	Billing records, as the law requires.
You ask the AI rep on our website	The question you type	Cloudflare Workers AI, through our connector. Never Anthropic.	The question (emails and phone numbers masked) and a keyed hash of your IP, for 30 days.
You turn on AI features	The facts for one request; never tokens, keys or secret values	Anthropic.	Not kept by Truehound; Anthropic does not train on it.

The sub-processors page names every provider, what it can see and where. Get advance notice of changes.

10 Request documents

Ask for the security overview, policies, DPA or written answers to your questionnaire. To be plain: there is no SOC 2 report and no ISO 27001 certificate to request, because Truehound holds neither today.

11 Documents

Security questionnaire answers: a CAIQ-lite style Q&A, each answer tied to where the product enforces it.

Open hook script (/atlas/hooks/truehound-hook.mjs): the AI tool-call hook that runs on your developers' laptops, readable before you install it.

Security overview (PDF) (/atlas/trust/truehound-security-overview.pdf): this page, printed.

Data Processing Agreement (PDF (/atlas/legal/truehound-dpa.pdf)), with the security and sub-processor annexes.

Sub-processors, with the 11 providers, where they process data, and the change feed.

Privacy Policy and Terms of Service.

Service levels: best effort, no uptime commitment unless an order form gives one.

Status, accessibility conformance report and the public roadmap.

Security overview for the architecture and the controls in more depth.

Vulnerability disclosure policy and security.txt (/atlas/.well-known/security.txt).

12 Contact

Security reports, questionnaires and privacy requests: truehoundhq@truehound.io. We acknowledge a vulnerability report within 1 business day.